Week 6: Advanced Security Audit & Final Deployment

[> Github]

Overview

A comprehensive security audit was conducted using industry-standard tools to identify vulnerabilities, apply fixes, and ensure secure deployment of the application.

---

1. Tools Used

- OWASP ZAP
- Nikto
- Lynis
- Burp Suite

---

2. Security Audit Results

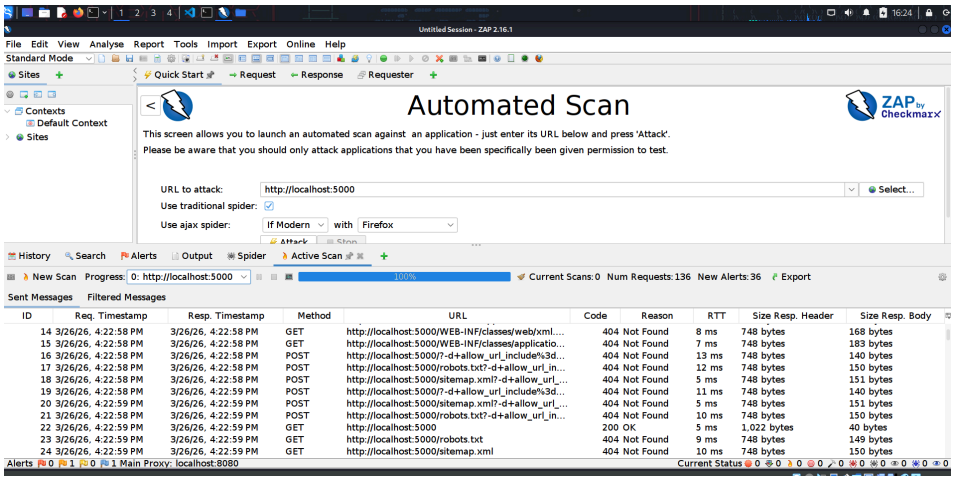
OWASP ZAP Scan

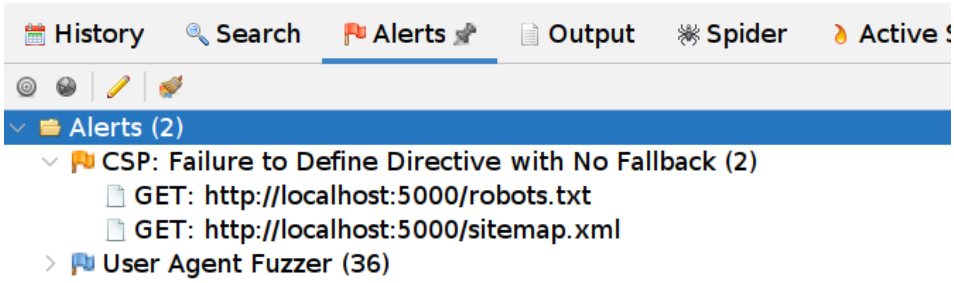
Issues Identified:

- Missing/weak security headers
- Potential XSS vulnerabilities
- Security misconfigurations

Fix Applied:

- Implemented security headers using Helmet
- Enabled Content Security Policy (CSP)
- Enforced HSTS





Nikto Scan

Issues Identified:

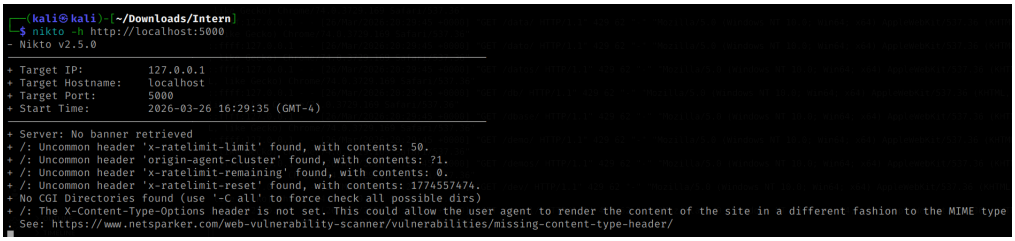
- Server information disclosure
- Missing protective headers

Command Used:

```
nikto -h http://localhost:5000
```

Fix Applied:

- Reduced server information exposure
- Strengthened HTTP headers



```
┌──(kali㉿kali)-[~/Downloads/Intern]
└─$ nikto -h http://localhost:5000
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          127.0.0.1
+ Target Hostname:    localhost
+ Target Port:        5000
+ Start Time:         2026-03-26 16:29:35 (GMT-4)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ /: Uncommon header 'x-ratelimit-limit' found, with contents: 50.
+ /: Uncommon header 'origin-agent-cluster' found, with contents: ?1.
+ /: Uncommon header 'x-ratelimit-remaining' found, with contents: 0.
+ /: Uncommon header 'x-ratelimit-reset' found, with contents: 1774557474.
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type
+ See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
```

Lynis Audit

Issues Identified:

- System security warnings
- Hardening recommendations

Command Used:

```
sudo lynis audit system
```

Note: Use gitHub version if apt failed

Fix Applied:

- Performed system audit
- Applied recommended hardening improvements

```
┌──(kali㉿kali)-[~/lynis]
└─$ sudo ./lynis audit system

[!] Change ownership of /home/kali/lynis/include/functions to 'root' or similar (found: kali wi
th UID 1000).

    Command:
      # chown 0:0 /home/kali/lynis/include/functions

[X] Security check failed

    Why do I see this error?
    ------------------------

    This is a protection mechanism to prevent the root user from executing user created files.
The files may be altered, or including malicious pieces of script.

    What can I do?
    --------------

    Option 1) Check if a trusted user created the files (e.g. due to using Git, Homebrew or sim
ilar).
              If you trust these files, you can decide to continue this run by pressing ENTER.

    Option 2) Change ownership of the related files (or full directory).

       Commands (full directory):
         # cd ..
         # chown -R 0:0 lynis
         # cd lynis
         # ./lynis audit system

[ Press ENTER to continue, or CTRL+C to cancel ]

[ Lynis 3.1.6 ]

################################################################################
  Lynis comes with ABSOLUTELY NO WARRANTY. This is free software, and you are
  welcome to redistribute it under the terms of the GNU General Public License.
  See the LICENSE file for details about using this software.

  2007-2025, CISOfy - https://cisofy.com/lynis/
  Enterprise support available (compliance, plugins, interface and tools)
```

```
kali@kali: ~/lynis
File  Actions  Edit  View  Help
[+] Initializing program
------------------------------------
  - Detecting OS ...                                          [ DONE ]
  - Checking profiles ...                                     [ DONE ]

  ---------------------------------------------------------
  Program version:           3.1.6
  Operating system:          Linux
  Operating system name:     Kali Linux
  Operating system version:  Rolling release
  End-of-life:               UNKNOWN
  Kernel version:            6.12.20
  Hardware platform:         x86_64
  Hostname:                  kali
  ---------------------------------------------------------
  Profiles:                  /home/kali/lynis/default.prf
  Log file:                  /var/log/lynis.log
  Report file:               /var/log/lynis-report.dat
  Report version:            1.0
  Plugin directory:          ./plugins
  ---------------------------------------------------------
  Auditor:                   [Not Specified]
  Language:                  en
  Test category:             all
  Test group:                all
  ---------------------------------------------------------
  - Program update status ...                                 [ NO UPDATE ]

[+] System tools
------------------------------------
  - Scanning available tools ...
  - Checking system binaries ...

[+] Plugins (phase 1)
------------------------------------
 Note: plugins have more extensive tests and may take several minutes to complete

  - Plugin: pam
    [..]
  - Plugin: systemd
    [................]
```

```
kali@kali: ~/lynis
File  Actions  Edit  View  Help
[+] Boot and services
  - Service Manager                                          [ systemd ]
  - Checking UEFI boot                                       [ DISABLED ]
  - Checking presence GRUB2                                  [ FOUND ]
    - Checking for password protection                       [ NONE ]
  - Check running services (systemctl)                       [ DONE ]
        Result: found 20 running services
  - Check enabled services at boot (systemctl)               [ DONE ]
        Result: found 20 enabled services
  - Check startup files (permissions)                        [ OK ]
  - Running 'systemd-analyze security'
      Unit name (exposure value) and predicate
      ----------------------------------------
    - ModemManager.service (value=6.3)                       [ MEDIUM ]
    - NetworkManager.service (value=7.8)                     [ EXPOSED ]
    - accounts-daemon.service (value=5.5)                    [ MEDIUM ]
    - colord.service (value=3.5)                             [ PROTECTED ]
    - containerd.service (value=9.6)                         [ UNSAFE ]
    - cron.service (value=9.6)                               [ UNSAFE ]
    - dbus.service (value=9.3)                               [ UNSAFE ]
    - docker.service (value=9.6)                             [ UNSAFE ]
    - emergency.service (value=9.5)                          [ UNSAFE ]
    - getty@tty1.service (value=9.6)                         [ UNSAFE ]
    - haveged.service (value=3.2)                            [ PROTECTED ]
    - lightdm.service (value=9.6)                            [ UNSAFE ]
    - nessusd.service (value=9.6)                            [ UNSAFE ]
    - ntpsec-rotate-stats.service (value=9.6)                [ UNSAFE ]
    - ntpsec-systemd-netif.service (value=9.6)               [ UNSAFE ]
    - ntpsec.service (value=9.2)                             [ UNSAFE ]
    - pcscd.service (value=9.6)                              [ UNSAFE ]
    - plymouth-start.service (value=9.5)                     [ UNSAFE ]
    - polkit.service (value=1.2)                             [ PROTECTED ]
    - rc-local.service (value=9.6)                           [ UNSAFE ]
    - rescue.service (value=9.5)                             [ UNSAFE ]
    - rpc-gssd.service (value=9.5)                           [ UNSAFE ]
    - rpc-statd-notify.service (value=9.5)                   [ UNSAFE ]
    - rpc-svcgssd.service (value=9.5)                        [ UNSAFE ]
    - rtkit-daemon.service (value=7.2)                       [ MEDIUM ]
    - smartmontools.service (value=9.6)                      [ UNSAFE ]
    - ssh.service (value=9.6)                                [ UNSAFE ]
    - systemd-ask-password-console.service (value=9.4)       [ UNSAFE ]
```

```
kali@kali: ~/
File  Actions  Edit  View  Help
[+] Kernel
  - Checking default runlevel                                [ runlevel 5 ]
  - Checking CPU support (NX/PAE)
    CPU support: PAE and/or NoeXecute supported              [ FOUND ]
  - Checking kernel version and release                      [ DONE ]
  - Checking kernel type                                     [ DONE ]
  - Checking loaded kernel modules                           [ DONE ]
      Found 112 active modules
  - Checking Linux kernel configuration file                 [ FOUND ]
  - Checking default I/O kernel scheduler                    [ NOT FOUND ]
  - Checking for available kernel update                     [ OK ]
  - Checking core dumps configuration
    - configuration in systemd conf files                    [ DEFAULT ]
    - configuration in /etc/profile                          [ DEFAULT ]
    - 'hard' configuration in /etc/security/limits.conf      [ ENABLED ]
    - 'soft' configuration in /etc/security/limits.conf      [ DISABLED ]
    - Checking setuid core dumps configuration               [ DISABLED ]
  - Check if reboot is needed                                [ NO ]

[+] Memory and Processes
  - Checking /proc/meminfo                                   [ FOUND ]
  - Searching for dead/zombie processes                      [ NOT FOUND ]
  - Searching for IO waiting processes                       [ NOT FOUND ]
  - Search prelink tooling                                   [ NOT FOUND ]

[+] Users, Groups and Authentication
  - Administrator accounts                                   [ OK ]
  - Unique UIDs                                              [ OK ]
  - Consistency of group files (grpck)                       [ OK ]
  - Unique group IDs                                         [ OK ]
  - Unique group names                                       [ OK ]
  - Password file consistency                                [ OK ]
  - Password hashing methods                                 [ OK ]
  - Checking password hashing rounds                         [ DISABLED ]
  - Query system users (non daemons)                         [ DONE ]
  - NIS+ authentication support                              [ NOT ENABLED ]
  - NIS authentication support                               [ NOT ENABLED ]
  - Sudoers file(s)                                          [ FOUND ]
    - Permissions for directory: /etc/sudoers.d              [ WARNING ]
```

```
kali@kali: ~/lynis
File  Actions  Edit  View  Help
  - Checking Linux single user mode authentication           [ OK ]
  - Determining default umask
    - umask (/etc/profile)                                   [ NOT FOUND ]
    - umask (/etc/login.defs)                                [ SUGGESTION ]
  - LDAP authentication support                              [ NOT ENABLED ]
  - Logging failed login attempts                            [ DISABLED ]

[+] Kerberos
------------------------------------
  - Check for Kerberos KDC and principals                    [ NOT FOUND ]

[+] Shells
------------------------------------
  - Checking shells from /etc/shells
    Result: found 13 shells (valid shells: 13).
    - Session timeout settings/tools                         [ NONE ]
  - Checking default umask values
    - Checking default umask in /etc/bash.bashrc             [ NONE ]
    - Checking default umask in /etc/profile                 [ NONE ]

[+] File systems
------------------------------------
  - Checking mount points
    - Checking /home mount point                             [ SUGGESTION ]
    - Checking /tmp mount point                              [ OK ]
    - Checking /var mount point                              [ SUGGESTION ]
  - Query swap partitions (fstab)                            [ OK ]
  - Testing swap partitions                                  [ OK ]
  - Testing /proc mount (hidepid)                            [ SUGGESTION ]
  - Checking for old files in /tmp                           [ OK ]
  - Checking /tmp sticky bit                                 [ OK ]
  - Checking /var/tmp sticky bit                             [ OK ]
  - ACL support root file system                             [ ENABLED ]
  - Mount options of /                                       [ NON DEFAULT ]
  - Mount options of /dev                                    [ PARTIALLY HARDENED ]
  - Mount options of /dev/shm                                [ PARTIALLY HARDENED ]
  - Mount options of /run                                    [ HARDENED ]
  - Mount options of /tmp                                    [ PARTIALLY HARDENED ]
  - Total without nodev:9 noexec:15 nosuid:8 ro or noexec (W^X): 15 of total 32
  - Checking Locate database                                 [ FOUND ]
  - Disable kernel support of some filesystems
```


```
[+] Kerberos
------------------------------------
  - Check for Kerberos KDC and principals                    [ NOT FOUND ]

[+] Shells
------------------------------------
  - Checking shells from /etc/shells
    Result: found 13 shells (valid shells: 13).
    - Session timeout settings/tools                         [ NONE ]
  - Checking default umask values
    - Checking default umask in /etc/bash.bashrc             [ NONE ]
    - Checking default umask in /etc/profile                 [ NONE ]

[+] File systems
------------------------------------
  - Checking mount points
    - Checking /home mount point                             [ SUGGESTION ]
    - Checking /tmp mount point                              [ OK ]
    - Checking /var mount point                              [ SUGGESTION ]
  - Query swap partitions (fstab)                            [ OK ]
  - Testing swap partitions                                  [ OK ]
  - Testing /proc mount (hidepid)                            [ SUGGESTION ]
  - Checking for old files in /tmp                           [ OK ]
  - Checking /tmp sticky bit                                 [ OK ]
  - Checking /var/tmp sticky bit                             [ OK ]
  - ACL support root file system                             [ ENABLED ]
  - Mount options of /                                       [ NON DEFAULT ]
  - Mount options of /dev                                    [ PARTIALLY HARDENED ]
  - Mount options of /dev/shm                                [ PARTIALLY HARDENED ]
  - Mount options of /run                                    [ HARDENED ]
  - Mount options of /tmp                                    [ PARTIALLY HARDENED ]
  - Total without nodev:9 noexec:15 nosuid:8 ro or noexec (W^X): 15 of total 32
  - Checking Locate database                                 [ FOUND ]
  - Disable kernel support of some filesystems
```


```
[+] USB Devices
------------------------------------
  - Checking usb-storage driver (modprobe config)            [ NOT DISABLED ]
  - Checking USB devices authorization                       [ ENABLED ]
  - Checking USBGuard                                        [ NOT FOUND ]
```

```
[+] Ports and packages
------------------------------------
  - Searching package managers
    - Searching RPM package manager                                  [ FOUND ]
      - Querying RPM package manager
    - Searching dpkg package manager                                 [ FOUND ]
      - Querying package manager

  [WARNING]: Test PKGS-7345 had a long execution: 15.598467 seconds

    - Query unpurged packages                                        [ FOUND ]
  - Checking APT package database                                    [ OK ]
W: OpenPGP signature verification failed: http://kali.download/kali kali-rolling InRelease: Sub
-process /usr/bin/sqv returned an error code (1), error message is: Missing key 827C8569F2518CC
677FECA1AED65462EC8D5E4C5, which is needed to verify signature.
E: The repository 'http://http.kali.org/kali kali-rolling InRelease' is not signed.
  - Checking vulnerable packages (apt-get only)                      [ DONE ]
  - Checking upgradeable packages                                    [ SKIPPED ]
  - Checking package audit tool                                      [ INSTALLED ]
    Found: apt-get
  - Toolkit for automatic upgrades                                   [ NOT FOUND ]

[+] Networking
------------------------------------
  - Checking IPv6 configuration                                      [ ENABLED ]
      Configuration method                                           [ AUTO ]
      IPv6 only                                                      [ NO ]
  - Checking configured nameservers
    - Testing nameservers
        Nameserver: 192.168.0.1                                      [ OK ]
    - Minimal of 2 responsive nameservers                            [ WARNING ]
  - Checking default gateway                                         [ DONE ]
  - Getting listening ports (TCP/UDP)                                [ DONE ]
  - Checking promiscuous interfaces                                  [ OK ]
  - Checking waiting connections                                     [ OK ]
  - Checking status DHCP client                                      [ NOT ACTIVE ]
  - Checking for ARP monitoring software                             [ NOT FOUND ]
  - Uncommon network protocols                                       [ 0 ]

[+] Printers and Spools
```

```
------------------------------------
  - Checking IPv6 configuration                                      [ ENABLED ]
      Configuration method                                           [ AUTO ]
      IPv6 only                                                      [ NO ]
  - Checking configured nameservers
    - Testing nameservers
        Nameserver: 192.168.0.1                                      [ OK ]
    - Minimal of 2 responsive nameservers                            [ WARNING ]
  - Checking default gateway                                         [ DONE ]
  - Getting listening ports (TCP/UDP)                                [ DONE ]
  - Checking promiscuous interfaces                                  [ OK ]
  - Checking waiting connections                                     [ OK ]
  - Checking status DHCP client                                      [ NOT ACTIVE ]
  - Checking for ARP monitoring software                             [ NOT FOUND ]
  - Uncommon network protocols                                       [ 0 ]

[+] Printers and Spools
------------------------------------
  - Checking cups daemon                                             [ NOT FOUND ]
  - Checking lp daemon                                               [ NOT RUNNING ]

[+] Software: e-mail and messaging
------------------------------------

[+] Software: firewalls
------------------------------------
  - Checking iptables kernel module                                  [ FOUND ]
    - Checking iptables policies of chains                           [ FOUND ]
      - Chain INPUT (table: filter, target: ACCEPT)                  [ ACCEPT ]
      - Chain INPUT (table: security, target: ACCEPT)                [ ACCEPT ]
    - Checking for empty ruleset                                     [ OK ]
    - Checking for unused rules                                      [ FOUND ]
  - Checking host based firewall                                     [ ACTIVE ]

[+] Software: webserver
------------------------------------
  - Checking Apache (binary /usr/sbin/apache2)                       [ FOUND ]
      Info: Configuration file found (/etc/apache2/apache2.conf)
      Info: No virtual hosts found
    * Loadable modules                                               [ FOUND (118) ]
        - Found 118 loadable modules
          mod_evasive: anti-DoS/brute force                          [ NOT FOUND ]
```

```
[+] Software: webserver
------------------------------------
  - Checking Apache (binary /usr/sbin/apache2)                [ FOUND ]
      Info: Configuration file found (/etc/apache2/apache2.conf)
      Info: No virtual hosts found
    * Loadable modules                                        [ FOUND (118) ]
        - Found 118 loadable modules
          mod_evasive: anti-DoS/brute force                   [ NOT FOUND ]
          mod_reqtimeout/mod_qos                              [ FOUND ]
          ModSecurity: web application firewall               [ NOT FOUND ]
  - Checking TraceEnable setting in:
      /etc/apache2/conf-available/javascript-common.conf      [ NOT FOUND ]
      /etc/apache2/conf-available/serve-cgi-bin.conf          [ NOT FOUND ]
      /etc/apache2/conf-available/other-vhosts-access-log.conf  [ NOT FOUND ]
      /etc/apache2/conf-available/localized-error-pages.conf  [ NOT FOUND ]
      /etc/apache2/conf-available/charset.conf                [ NOT FOUND ]
      /etc/apache2/conf-available/security.conf               [ FOUND ]
      /etc/apache2/mods-enabled/mpm_prefork.conf              [ NOT FOUND ]
      /etc/apache2/mods-enabled/reqtimeout.conf               [ NOT FOUND ]
      /etc/apache2/mods-enabled/php8.4.conf                   [ NOT FOUND ]
      /etc/apache2/mods-enabled/mime.conf                     [ NOT FOUND ]
      /etc/apache2/mods-enabled/alias.conf                    [ NOT FOUND ]
      /etc/apache2/mods-enabled/autoindex.conf                [ NOT FOUND ]
      /etc/apache2/mods-enabled/status.conf                   [ NOT FOUND ]
      /etc/apache2/mods-enabled/deflate.conf                  [ NOT FOUND ]
      /etc/apache2/mods-enabled/negotiation.conf              [ NOT FOUND ]
      /etc/apache2/mods-enabled/dir.conf                      [ NOT FOUND ]
      /etc/apache2/mods-enabled/setenvif.conf                 [ NOT FOUND ]
      /etc/apache2/sites-enabled/000-default.conf             [ NOT FOUND ]
      /etc/apache2/mods-available/mpm_prefork.conf            [ NOT FOUND ]
      /etc/apache2/mods-available/cgid.conf                   [ NOT FOUND ]
      /etc/apache2/mods-available/proxy_connect.conf          [ NOT FOUND ]
      /etc/apache2/mods-available/actions.conf                [ NOT FOUND ]
      /etc/apache2/mods-available/reqtimeout.conf             [ NOT FOUND ]
      /etc/apache2/mods-available/php8.2.conf                 [ NOT FOUND ]
      /etc/apache2/mods-available/php8.4.conf                 [ NOT FOUND ]
      /etc/apache2/mods-available/mime.conf                   [ NOT FOUND ]
      /etc/apache2/mods-available/alias.conf                  [ NOT FOUND ]
      /etc/apache2/mods-available/autoindex.conf              [ NOT FOUND ]
      /etc/apache2/mods-available/dav_fs.conf                 [ NOT FOUND ]
      /etc/apache2/mods-available/mime_magic.conf             [ NOT FOUND ]
      /etc/apache2/mods-available/info.conf                   [ NOT FOUND ]
```

```
[+] SSH Support
------------------------------------
  - Checking running SSH daemon                               [ NOT FOUND ]

[+] SNMP Support
------------------------------------
  - Checking running SNMP daemon                              [ NOT FOUND ]

[+] Databases
------------------------------------
  - MySQL process status                                      [ FOUND ]

[+] LDAP Services
------------------------------------
  - Checking OpenLDAP instance                                [ NOT FOUND ]

[+] PHP
------------------------------------
  - Checking PHP                                              [ FOUND ]
    - Checking PHP disabled functions                         [ FOUND ]
    - Checking expose_php option                              [ OFF ]
    - Checking enable_dl option                               [ OFF ]
    - Checking allow_url_fopen option                         [ ON ]
    - Checking allow_url_include option                       [ OFF ]
    - Checking listen option                                  [ OK ]

[+] Squid Support
------------------------------------
  - Checking running Squid daemon                             [ NOT FOUND ]

[+] Logging and files
------------------------------------
  - Checking for a running log daemon                         [ OK ]
    - Checking Syslog-NG status                               [ NOT FOUND ]
    - Checking systemd journal status                         [ FOUND ]
    - Checking Metalog status                                 [ NOT FOUND ]
    - Checking RSyslog status                                 [ NOT FOUND ]
    - Checking RFC 3195 daemon status                         [ NOT FOUND ]
    - Checking minilogd instances                             [ NOT FOUND ]
    - Checking wazuh-agent daemon status                      [ NOT FOUND ]
```

```
[+] Insecure services
------------------------------------
  - Installed inetd package                                  [ NOT FOUND ]
  - Installed xinetd package                                 [ OK ]
    - xinetd status                                          [ NOT ACTIVE ]
  - Installed rsh client package                             [ SUGGESTION ]
  - Installed rsh server package                             [ OK ]
  - Installed telnet client package                          [ OK ]
  - Installed telnet server package                          [ NOT FOUND ]
  - Checking NIS client installation                         [ OK ]
  - Checking NIS server installation                         [ OK ]
  - Checking TFTP client installation                        [ SUGGESTION ]
  - Checking TFTP server installation                        [ SUGGESTION ]

[+] Banners and identification
------------------------------------
  - /etc/issue                                               [ FOUND ]
    - /etc/issue contents                                    [ WEAK ]
  - /etc/issue.net                                           [ FOUND ]
    - /etc/issue.net contents                                [ WEAK ]

[+] Scheduled tasks
------------------------------------
  - Checking crontab and cronjob files                       [ DONE ]

[+] Accounting
------------------------------------
  - Checking accounting information                          [ NOT FOUND ]
  - Checking sysstat accounting data                         [ DISABLED ]
  - Checking auditd                                          [ NOT FOUND ]

[+] Time and Synchronization
------------------------------------

[+] Cryptography
------------------------------------
  - Checking for expired SSL certificates [0/155]            [ NONE ]

  [WARNING]: Test CRYP-7902 had a long execution: 78.937857 seconds

  - Found 0 encrypted and 1 unencrypted swap devices in use. [ OK ]
  - Kernel entropy is sufficient                             [ YES ]
  - HW RNG & rngd                                            [ NO ]
  - SW prng                                                  [ YES ]
  - MOR variable not found                                   [ WEAK ]

[+] Virtualization
------------------------------------

[+] Containers
```

```
[+] Security frameworks
------------------------------------
  - Checking presence AppArmor                               [ FOUND ]
    - Checking AppArmor status                               [ ENABLED ]
        Found 120 unconfined processes
  - Checking presence SELinux                                [ NOT FOUND ]
  - Checking presence TOMOYO Linux                           [ NOT FOUND ]
  - Checking presence grsecurity                             [ NOT FOUND ]
  - Checking for implemented MAC framework                   [ OK ]

[+] Software: file integrity
------------------------------------
  - Checking file integrity tools
  - dm-integrity (status)                                    [ DISABLED ]
  - dm-verity (status)                                       [ DISABLED ]
  - Checking presence integrity tool                         [ NOT FOUND ]

[+] Software: System tooling
------------------------------------
  - Checking automation tooling
  - Automation tooling                                       [ NOT FOUND ]
  - Checking for IDS/IPS tooling                             [ NONE ]

[+] Software: Malware
------------------------------------
  - Malware software components                               [ NOT FOUND ]

[+] File Permissions
------------------------------------
  - Starting file permissions check
    File: /boot/grub/grub.cfg                                [ OK ]
    File: /etc/crontab                                       [ SUGGESTION ]
    File: /etc/group                                         [ OK ]
    File: /etc/group-                                        [ OK ]
    File: /etc/hosts.allow                                   [ OK ]
    File: /etc/hosts.deny                                    [ OK ]
    File: /etc/issue                                         [ OK ]
    File: /etc/issue.net                                     [ OK ]
    File: /etc/motd                                          [ OK ]
    File: /etc/passwd                                        [ OK ]
    File: /etc/passwd-                                       [ OK ]
    File: /etc/ssh/sshd_config                               [ SUGGESTION ]
    Directory: /root/.ssh                                    [ OK ]
    Directory: /etc/cron.d                                   [ SUGGESTION ]
```

```
[+] Kernel Hardening
------------------------------------------------------------
  - Comparing sysctl key pairs with scan profile
    - dev.tty.ldisc_autoload (exp: 0)                         [ DIFFERENT ]
    - fs.protected_fifos (exp: 2)                             [ DIFFERENT ]
    - fs.protected_hardlinks (exp: 1)                         [ OK ]
    - fs.protected_regular (exp: 2)                           [ OK ]
    - fs.protected_symlinks (exp: 1)                          [ OK ]
    - fs.suid_dumpable (exp: 0)                               [ OK ]
    - kernel.core_uses_pid (exp: 1)                           [ OK ]
    - kernel.ctrl-alt-del (exp: 0)                            [ OK ]
    - kernel.dmesg_restrict (exp: 1)                          [ DIFFERENT ]
    - kernel.kptr_restrict (exp: 2)                           [ DIFFERENT ]
    - kernel.modules_disabled (exp: 1)                        [ DIFFERENT ]
    - kernel.perf_event_paranoid (exp: 2 3 4)                 [ OK ]
    - kernel.randomize_va_space (exp: 2)                      [ OK ]
    - kernel.sysrq (exp: 0)                                   [ DIFFERENT ]
    - kernel.unprivileged_bpf_disabled (exp: 1)               [ DIFFERENT ]
    - kernel.yama.ptrace_scope (exp: 1 2 3)                   [ DIFFERENT ]
    - net.core.bpf_jit_harden (exp: 2)                        [ DIFFERENT ]
    - net.ipv4.conf.all.accept_redirects (exp: 0)             [ OK ]
    - net.ipv4.conf.all.accept_source_route (exp: 0)          [ OK ]
    - net.ipv4.conf.all.bootp_relay (exp: 0)                  [ OK ]
    - net.ipv4.conf.all.forwarding (exp: 0)                   [ DIFFERENT ]
    - net.ipv4.conf.all.log_martians (exp: 1)                 [ DIFFERENT ]
    - net.ipv4.conf.all.mc_forwarding (exp: 0)                [ OK ]
    - net.ipv4.conf.all.proxy_arp (exp: 0)                    [ OK ]
    - net.ipv4.conf.all.rp_filter (exp: 1)                    [ DIFFERENT ]
    - net.ipv4.conf.all.send_redirects (exp: 0)               [ DIFFERENT ]
    - net.ipv4.conf.default.accept_redirects (exp: 0)         [ DIFFERENT ]
    - net.ipv4.conf.default.accept_source_route (exp: 0)      [ OK ]
    - net.ipv4.conf.default.log_martians (exp: 1)             [ DIFFERENT ]
    - net.ipv4.icmp_echo_ignore_broadcasts (exp: 1)           [ OK ]
    - net.ipv4.icmp_ignore_bogus_error_responses (exp: 1)     [ OK ]
    - net.ipv4.tcp_syncookies (exp: 1)                        [ OK ]
    - net.ipv4.tcp_timestamps (exp: 0 1)                      [ OK ]
    - net.ipv6.conf.all.accept_redirects (exp: 0)             [ DIFFERENT ]
    - net.ipv6.conf.all.accept_source_route (exp: 0)          [ OK ]
    - net.ipv6.conf.default.accept_redirects (exp: 0)         [ DIFFERENT ]
    - net.ipv6.conf.default.accept_source_route (exp: 0)      [ OK ]

[+] Hardening
------------------------------------------------------------
    - Installed compiler(s)                                   [ FOUND ]
    - Installed malware scanner                               [ NOT FOUND ]
    - Non-native binary formats                               [ FOUND ]

[+] Custom tests
------------------------------------------------------------
  - Running custom tests...                                   [ NONE ]
```

```
================================================================================

  -[ Lynis 3.1.6 Results ]-

  Warnings (1):
  ----------------------------
  ! Couldn't find 2 responsive nameservers [NETW-2705]
      https://cisofy.com/lynis/controls/NETW-2705/

  Suggestions (45):
  -----------------------------
  * Set a password on GRUB boot loader to prevent altering boot configuration (e.g. boot in sin
gle user mode without password) [BOOT-5122]
    - Related resources
      * Website: https://cisofy.com/lynis/controls/BOOT-5122/

  * Determine runlevel and services at startup [BOOT-5180]
    - Related resources
      * Website: https://cisofy.com/lynis/controls/BOOT-5180/

  * Consider hardening system services [BOOT-5264]
    - Details  : Run '/usr/bin/systemd-analyze security SERVICE' for each service
    - Related resources
      * Article: Systemd features to secure service files: https://linux-audit.com/systemd/syst
emd-features-to-secure-units-and-services/
      * Website: https://cisofy.com/lynis/controls/BOOT-5264/

  * Configure password hashing rounds in /etc/login.defs [AUTH-9230]
    - Related resources
      * Article: Linux password security: hashing rounds: https://linux-audit.com/authenticatio
n/configure-the-minimum-password-length-on-linux-systems/
      * Website: https://cisofy.com/lynis/controls/AUTH-9230/

  * Install a PAM module for password strength testing like pam_cracklib or pam_passwdqc or lib
pam-passwdqc [AUTH-9262]
    - Related resources
      * Article: Configure minimum password length for Linux systems: https://linux-audit.com/c
onfigure-the-minimum-password-length-on-linux-systems/
      * Website: https://cisofy.com/lynis/controls/AUTH-9262/

  * When possible set expire dates for all password protected accounts [AUTH-9282]
    - Related resources
      * Website: https://cisofy.com/lynis/controls/AUTH-9282/

  * Configure minimum password age in /etc/login.defs [AUTH-9286]
    - Related resources
      * Article: Configure minimum password length for Linux systems: https://linux-audit.com/c
onfigure-the-minimum-password-length-on-linux-systems/
      * Website: https://cisofy.com/lynis/controls/AUTH-9286/

  * Configure maximum password age in /etc/login.defs [AUTH-9286]
    - Related resources
```

```
  * Change the allow_url_fopen line to: allow_url_fopen = Off, to disable downloads via PHP [PH
P-2376]
    - Related resources
      * Website: https://cisofy.com/lynis/controls/PHP-2376/

  * Enable logging to an external logging host for archiving purposes and additional protection
 [LOGG-2154]
    - Related resources
      * Website: https://cisofy.com/lynis/controls/LOGG-2154/

  * Check what deleted files are still in use and why. [LOGG-2190]
    - Related resources
      * Website: https://cisofy.com/lynis/controls/LOGG-2190/

  * Remove rsh client when it is not in use or replace with the more secure SSH package [INSE-8
300]
    - Related resources
      * Website: https://cisofy.com/lynis/controls/INSE-8300/

  * It is recommended that TFTP be removed, unless there is a specific need for TFTP (such as a
 boot server) [INSE-8318]
    - Related resources
      * Website: https://cisofy.com/lynis/controls/INSE-8318/

  * Removing the atftpd package decreases the risk of the accidental (or intentional) activatio
n of tftp services [INSE-8320]
    - Related resources
      * Website: https://cisofy.com/lynis/controls/INSE-8320/

  * Add a legal banner to /etc/issue, to warn unauthorized users [BANN-7126]
    - Related resources
      * Article: The real purpose of login banners: https://linux-audit.com/the-real-purpose-of
-login-banners-on-linux/
      * Website: https://cisofy.com/lynis/controls/BANN-7126/

  * Add legal banner to /etc/issue.net, to warn unauthorized users [BANN-7130]
    - Related resources
      * Article: The real purpose of login banners: https://linux-audit.com/the-real-purpose-of
-login-banners-on-linux/
      * Website: https://cisofy.com/lynis/controls/BANN-7130/

  * Enable process accounting [ACCT-9622]
    - Related resources
      * Website: https://cisofy.com/lynis/controls/ACCT-9622/

  * Enable sysstat to collect accounting (disabled) [ACCT-9626]
    - Related resources
      * Website: https://cisofy.com/lynis/controls/ACCT-9626/
```


```
  * Change the allow_url_fopen line to: allow_url_fopen = Off, to disable downloads via PHP [PH
P-2376]
    - Related resources
      * Website: https://cisofy.com/lynis/controls/PHP-2376/

  * Enable logging to an external logging host for archiving purposes and additional protection
 [LOGG-2154]
    - Related resources
      * Website: https://cisofy.com/lynis/controls/LOGG-2154/

  * Check what deleted files are still in use and why. [LOGG-2190]
    - Related resources
      * Website: https://cisofy.com/lynis/controls/LOGG-2190/

  * Remove rsh client when it is not in use or replace with the more secure SSH package [INSE-8
300]
    - Related resources
      * Website: https://cisofy.com/lynis/controls/INSE-8300/

  * It is recommended that TFTP be removed, unless there is a specific need for TFTP (such as a
 boot server) [INSE-8318]
    - Related resources
      * Website: https://cisofy.com/lynis/controls/INSE-8318/

  * Removing the atftpd package decreases the risk of the accidental (or intentional) activatio
n of tftp services [INSE-8320]
    - Related resources
      * Website: https://cisofy.com/lynis/controls/INSE-8320/

  * Add a legal banner to /etc/issue, to warn unauthorized users [BANN-7126]
    - Related resources
      * Article: The real purpose of login banners: https://linux-audit.com/the-real-purpose-of
-login-banners-on-linux/
      * Website: https://cisofy.com/lynis/controls/BANN-7126/

  * Add legal banner to /etc/issue.net, to warn unauthorized users [BANN-7130]
    - Related resources
      * Article: The real purpose of login banners: https://linux-audit.com/the-real-purpose-of
-login-banners-on-linux/
      * Website: https://cisofy.com/lynis/controls/BANN-7130/

  * Enable process accounting [ACCT-9622]
    - Related resources
      * Website: https://cisofy.com/lynis/controls/ACCT-9622/

  * Enable sysstat to collect accounting (disabled) [ACCT-9626]
    - Related resources
      * Website: https://cisofy.com/lynis/controls/ACCT-9626/
```

```
Follow-up:
  ------------------
  - Show details of a test (lynis show details TEST-ID)
  - Check the logfile for all details (less /var/log/lynis.log)
  - Read security controls texts (https://cisofy.com)
  - Use --upload to upload data to central system (Lynis Enterprise users)

================================================================================

  Lynis security scan details:

  Scan mode:
  Normal [V]  Forensics [ ]  Integration [ ]  Pentest [ ]

  Lynis modules:
  - Compliance status      [?]
  - Security audit         [V]
  - Vulnerability scan     [V]

  Details:
  Hardening index : 66 [#############        ]
  Tests performed : 289
  Plugins enabled : 2

  Software components:
  - Firewall               [V]
  - Intrusion software     [X]
  - Malware scanner        [X]

  Files:
  - Test and debug information      : /var/log/lynis.log
  - Report data                     : /var/log/lynis-report.dat

================================================================================

  Notice: No OS entry was found in the end-of-life database

  What to do:
  Please submit a pull request on GitHub to include your OS version and the end date of this OS
version is being supported
  URL: https://github.com/CISOfy/lynis

================================================================================

  Lynis 3.1.6

  Auditing, system hardening, and compliance for UNIX-based systems
```

OWASP Top 10 Compliance

✔ Injection → Prevented using input validation
✔ Broken Authentication → Secured with API key
✔ Security Misconfiguration → Fixed with headers
✔ XSS → Mitigated using CSP
✔ CSRF → Protected (implemented earlier)

---

4. Secure Deployment Practices

Issues Identified:

- Vulnerable dependencies

- Hardcoded sensitive data

Commands Used:

```
npm audit
npm audit fix
```

Docker Build & Scan:

```
docker build -t secure-app .
docker scan secure-app
```

Fix Applied:

- Fixed vulnerable dependencies
- Moved API key to environment variables (.env)
- Enabled logging for monitoring

Note: While I successfully updated the `Dockerfile` to use a minimal base image (`node:18-alpine`) and implemented a non-root user (`USER node`), I encountered a system-level compatibility error when attempting to run `docker scout`. The Docker Scout CLI plugin failed to install on this specific Kali Linux environment due to binary path restrictions. However, the successful `docker build` (see screenshot) confirms that the security instructions were correctly parsed and baked into the image layers."

Final Penetration Testing

Penetration testing was conducted using Burp Suite to validate implemented security controls.

Attacks Performed:

- Brute-force login attempts
- SQL Injection

- API authentication bypass
- Invalid input testing
- XSS injection

Tool Used:

`burpsuite`

Results:

✔ Brute-force → Blocked (429 Too Many Requests)
✔ SQL Injection → Failed
✔ API access without key → Blocked (403 Forbidden)
✔ Invalid input → Rejected
✔ XSS → Prevented

---

6. Final Conclusion

The application has been successfully secured through multiple layers of protection.

✔ Vulnerabilities identified and fixed
✔ Security best practices implemented
✔ Application ready for secure deployment